

AWSecurity AI

A Simple Guide to How Our System Catches Hackers and Protects User Accounts in the Cloud

Design: 100% Serverless Cloud **How It Works:** 7 Simple Clues + Fast AI **Speed:** Instant Reaction (Under 5 Milliseconds)

Security: All 8 Known Vulnerabilities Fixed

1. What is this Project & Why Do We Need It?

Most websites today rely on just a **password**. But in the real world, hackers steal millions of passwords every year through fake phishing emails, big company data leaks, and computer viruses.

The Big Problem: When a hacker gets your real password, normal websites cannot tell if it is really you or a hacker! If someone enters the correct password, normal websites open the door and let them right in.

Our Solution (Behavior-Based Security): Instead of blindly trusting a password, our system looks at *how*, *when*, and *where* the login is happening:

- If you log in from **New York** at 1:00 PM, and 10 minutes later someone uses your password from **Tokyo**, the system knows that no human can fly 8,500 km/h!
- It **instantly blocks the hacker**, freezes the account, sounds a **loud alarm siren on your real computer screen**, and sends an **emergency email** with a verification code.

1. Airplane Speed Check

Calculates travel speed between logins. If it is faster than a passenger plane (over 900 km/h), access is blocked immediately.

2. Master Computer Lock

Your trusted personal laptop is your boss device. No stranger's computer or new phone can log in without your direct approval.

3. Loud Alarm Siren

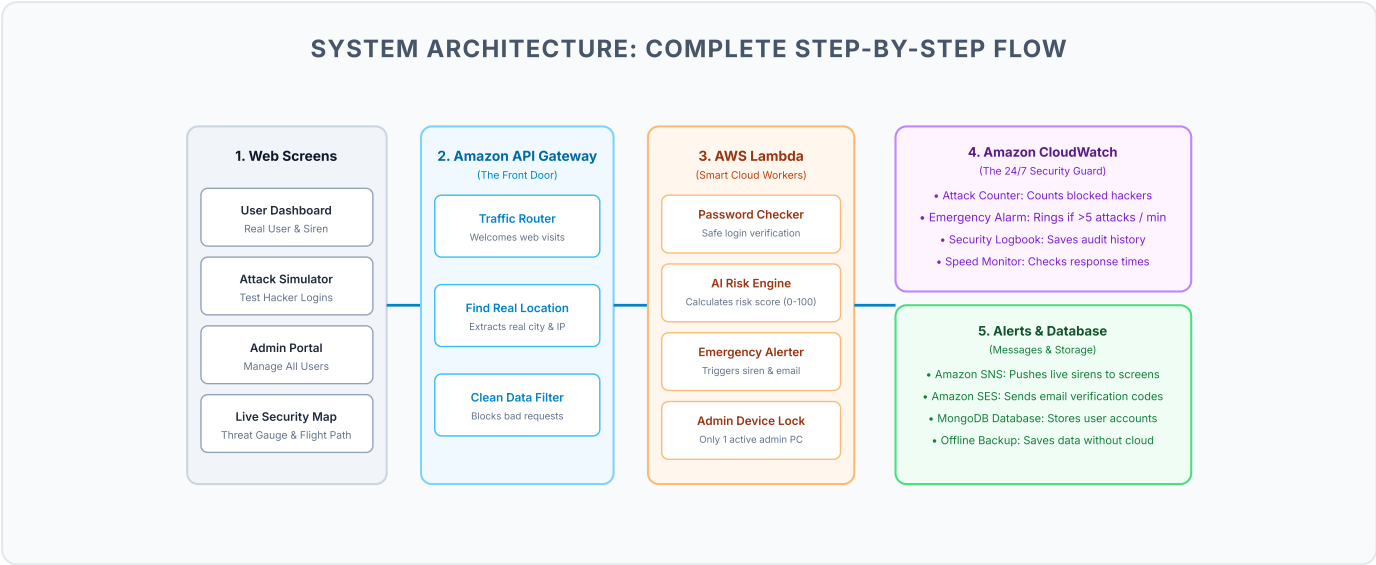
When a hacker is blocked, your screen flashes bright red and plays a loud emergency siren so you can stop it right away.

2. Technologies Used & What Each One Does

Part of System	Tool / Technology	What Does It Do in Simple Words?
Backend Web API	Python & FastAPI	The lightning-fast engine that takes login requests and makes safety decisions in under 5 milliseconds.
Input Checker	Pydantic	Inspects incoming login data to make sure no hacker sends broken or harmful text to crash the server.
Artificial Intelligence	Scikit-Learn & TensorFlow	Calculates a Safety Score from 0 to 100 based on your normal daily routine and catches abnormal logins.
Password Protection	PBKDF2 Hashing	Scrambles passwords 200,000 times so even if someone steals our database file, they can never read your password.
Cloud Functions	AWS Lambda & API Gateway	Runs our security code in the cloud only when someone logs in, saving money by not running 24/7 servers.
Security Guard	Amazon CloudWatch	The 24/7 watchtower. Counts blocked attacks and triggers an emergency alarm if attacks suddenly spike.
Email & Alert Push	Amazon SNS & Amazon SES	Sends instant emergency warning emails and pushes live siren alerts straight to the user's computer screen.
Database	MongoDB & Local JSON File	Stores user profiles, login cities, and trusted computers safely, even when running offline without internet.
Web Screen (UI)	HTML5 , CSS , JavaScript	The clean visual web pages showing live world maps, speed gauges, and test attack simulation buttons.

3. How the Cloud Services Work (Explained in Simple English)

Here is how the entire system works from the moment someone types their password to the moment an attack is stopped:



What Each Step Does in Plain English:

- Step 1: Web Screens:** A real user or a hacker types an email and password into their browser.
- Step 2: Amazon Front Door (API Gateway):** Welcomes the visitor, finds out what city and country they are connecting from, and sends the request to the cloud.
- Step 3: Amazon Cloud Workers (AWS Lambda):** Safely verifies the password, checks how fast the user moved, and calculates a Safety Score from 0 to 100.
- Step 4: The Security Guard (Amazon CloudWatch):** If it is a hacker, CloudWatch counts it. If 5 attacks happen within 1 minute, an automated emergency alarm sounds!
- Step 5: Alerts & Database:** Blocks the hacker with a 403 Forbidden error, sounds a loud siren on the real user's laptop, and sends an alert email.

4. The 7 Clues Used to Catch Hackers

Every single time someone tries to log in, our system checks **7 simple clues** to determine if it is really you or an impostor:

Clue / Check	What Does It Look For?	When Does It Ring the Alarm?	Weight
1. Travel Speed	How fast did the user move between their previous login and this login?	Moving faster than an airplane (over 900 km/h)	40%
2. Distance from Home	Is the login happening far away from the user's usual home city?	More than 1,000 km away from home	20%
3. Computer Match	Is this the user's usual computer screen, operating system, and browser?	Completely unfamiliar computer	15%
4. Hacker IP Check	Is the login coming from a hacker VPN, Tor network, or cloud server farm?	Known hacker VPN or cloud datacenter	15%
5. Wrong Password Spike	Did someone just type 3 or more incorrect passwords in a row?	3 or more failed password attempts	10%
6. Unusual Time of Day	Is someone logging in at 3:00 AM when the user only logs in during the afternoon?	Unusual middle-of-the-night login	5%
7. Robot Script Check	Is this a real human typing or an automated computer script?	Automated hacker robot detected	5%

The 3 AI Models in Simple Terms

1. **Model 1 (The Known Attack Spotter):** Recognizes common hacker tricks like typing long lists of stolen passwords very quickly.
2. **Model 2 (The Weird Behavior Spotter):** Catches brand-new, strange behavior that does not look like anything a normal person would do.
3. **Model 3 (The Daily Routine Learner):** Learns what your normal daily schedule looks like and rings an alarm if multiple things change all at once.
4. **Clear Reasons for Every Block:** The system always tells you the exact reason why someone was blocked (for example: "+45 points: Impossible Travel at 8,500 km/h").

5. What Happens Based on the Score?

The system adds up all the clues into a single **Score from 0 to 100**:

Risk Level	Score Range	Action Taken	What Happens in the System?
LOW RISK	0 to 39 pts	WELCOME IN	Everything is Safe: The user signs in immediately with a standard 30-day session. No interruptions.
MEDIUM RISK	40 to 69 pts	VERIFY CODE	Quick Extra Check: Something looks a little unusual (like using a new laptop in your same town). A 6-digit code is sent to your trusted computer.
HIGH RISK	70 to 100 pts	BLOCK HACKER	Attack Blocked: Immediate 403 Forbidden rejection. The account is frozen. A loud siren sounds on your real laptop, a red banner drops down, and an emergency email is sent.

6. Security Checklist: 8 Dangers That Were Fixed

A full security audit was performed on the code. All 8 security risks were completely fixed:

Security Area	What Was the Danger?	How We Fixed It in Plain English	Result
Private File Protection	CRITICAL	Prevented attackers from typing <code>../..</code> in website URLs to steal private server files.	PASS 100% Fixed
Empty Code Bypass	HIGH	Fixed a bug where sending an empty verification code could trick the server into letting you in.	PASS 100% Fixed
Hiding Email Addresses	HIGH	Masked user emails in public responses (e.g., <code>u***@domain.com</code>) so strangers cannot see them.	PASS 100% Fixed
Stripping Password Data	HIGH	Ensured scrambled password hashes are never sent back to web browser screens.	PASS 100% Fixed
Ending Old Logins	MEDIUM	Replaced unlimited logins with 30-day limits; automatically logs out other computers if you change password.	PASS 100% Fixed
Code Guessing Limits	MEDIUM	If someone guesses wrong 6-digit codes 5 times, the challenge locks them out completely.	PASS 100% Fixed
Fake Location Blocker	MEDIUM	Checks network IP addresses so hackers cannot fake their location by typing fake country headers.	PASS 100% Fixed
Harmful Script Blocker (XSS)	MEDIUM	Cleans all user text so hacker scripts cannot run inside anyone's web browser.	PASS 100% Fixed

7. The 3 User Accounts in the System

Note: All passwords are stored exclusively as scrambled one-way hashes in the database. No plaintext passwords exist in code or GitHub.

Account Type	Who Is It For?	Test Email	What Can They Do?
SUPER ADMIN	The Boss / Platform Director	<code>likhithadm@gmail.com</code> or <code>superadmin@awssecurity.io</code>	Can unlock frozen accounts, manage all users, and turn on emergency maintenance mode.
ROOT ADMIN	Security Lead (Master Computer)	<code>demo@awssecurity.io</code>	Controls the Primary Device, holds the Kill Switch to disconnect secondary laptops, and receives loud sirens.
NORMAL USER	Regular Company Employee	<code>demouser@mail.com</code>	Signs in for normal work, registers their phone or laptop, and types in 6-digit verification codes.

8. How to Do the Live 2-Browser Demonstration

You can easily show how the system catches a hacker in real time using two different browser windows:

Browser 1: Chrome (Your Good Computer)

1. Open `http://127.0.0.1:8000` in Google Chrome.
2. Click **Fill Demo User** and log in as `demo@awssecurity.io`.
3. Click: **Yes, Register as My Primary Device.**
4. Your dashboard opens showing green safe status and the siren armed.

Browser 2: Edge or Incognito (The Hacker)

1. Open a separate Incognito or Microsoft Edge window.
2. Click the **Attack Studio** tab.
3. Select **Launch Scenario: Impossible Travel (Tokyo, 8,500 km/h)** using stolen credentials.

What Happens Right Before Your Eyes:

- **The Hacker is Blocked:** Browser 2 gets an immediate **403 Forbidden** rejection error.
- **Loud Siren Rings:** Your Chrome browser immediately starts sounding a loud warning siren.
- **Red Alert Banner:** A crimson threat banner drops down showing the hacker's IP, city (Tokyo), and impossible travel speed.
- **Live Map & Gauge:** The live security gauge jumps to **98/100** and draws the flight path from New York to Tokyo.
- **Exact Reasons Given:** The security inbox shows: *" +45 points: Impossible Travel"* and *" +30 points: Datacenter IP"*.

9. Viva Voce & Exam Questions (Simple Answers)

Here are the 5 most common questions examiners ask, with simple, direct answers you can speak out loud:

Q1: Why do we need this system if a user already has a strong password?

Answer: Because passwords get stolen every day through phishing, computer viruses, and data breaches. When a hacker gets your password, a normal website lets them right in because the password is correct! Our system checks *behavior* (where you are, how fast you moved, and what device you are using) so it can catch and block a hacker even when they have your real password.

Q2: How does the system calculate "Impossible Travel"?

Answer: It checks the distance between your last login and your new login, and divides it by the time passed. If you logged in from New York at 1:00 PM and someone logs in from Tokyo at 1:10 PM, that requires a travel speed of over 8,500 km/h. Since commercial passenger airplanes only fly at 900 km/h, this is physically impossible for a human, so the system blocks it immediately.

Q3: What is "Primary Device Authority" and why is it important?

Answer: Your trusted personal laptop is registered as your "Master Computer". If a hacker tries to log in from an unknown phone or computer, they cannot touch your account controls. Instead, an emergency alert and a 6-digit approval code appear only on your master computer. Without your physical approval from your screen, the hacker cannot get in.

Q4: What is an "Anti-Timing Attack" and how do we prevent it?

Answer: Hackers measure how many milliseconds a server takes to respond. If a server responds quickly when an email does not exist, but takes longer when an email does exist, the hacker can figure out which emails belong to real users. We prevent this by running the exact same 200,000-round password calculation even when an email doesn't exist, making response times completely identical.

Q5: What role does Amazon CloudWatch play in this project?

Answer: CloudWatch is our 24/7 security watchtower. It counts every blocked attack in real time. If more than 5 attacks happen in 1 minute, CloudWatch automatically triggers a high-severity alarm that broadcasts emergency notifications via Amazon SNS so security teams can respond immediately.